

Bodeum Backend

Spring Boot 평가 기준 적합성 점검 보고서

API 설계·구현, 배포·보안, 데이터베이스, 협업 항목 대조

종합 판단	상당 부분 충족하나, 인증·인가 설정상 중대한 감점 위험이 있어 완전 충족으로 판단하기 어려움
최우선 조치	관리자 동기화 API 보호 및 info-items 경로의 광범위한 permitAll 제거
점검 기준일	2026-08-09 / develop 브랜치 / 작업 트리 깨끗함
검토 범위	약 87개 API 매핑, 보안·예외 처리·DB·배포 구성, 92개 테스트 소스

평가 기준 원문

Spring Boot 최종 과제 평가 기준 (makeus-challenge.notion.site)

※ 본 보고서는 저장소 코드와 공개된 평가표를 대조한 결과다. 시연 영상, 팀 노션, 실제 PR 리뷰 및 비공개 배포 URL은 별도 제출자료 확인이 필요하다.

1. 한눈에 보는 결과

평가 영역	판단	핵심 근거
API 설계	부분 충족	리소스 중심 URI와 메서드 사용은 대체로 양호하나 POST 토글 API가 남아 있음
API 구현	부분 충족	공통 응답·예외 처리는 양호. 전체 테스트 완료 및 시연 영상 일치 여부는 확인 불가
배포·보안	보완 필요	배포 구성은 갖췄으나 관리자 API와 후기 쓰기 API의 공개 매치가 중대한 위험
DB 설계	코드상 양호	JPA 관계, 제약조건, Flyway, 운영 validate 적용. 전체 ERD와 설계 이유는 팀 노션 확인 필요
협업	대체로 충족	Git Flow, 이슈·PR 템플릿, CI, 리뷰 규칙 존재. 실제 리뷰 비율은 GitHub 확인 필요

우선순위

P0	관리자 API 인증·권한 적용	외부 호출에 의한 대량 동기화와 자원 소모 차단
P0	info-items 광역 permitAll 제거	후기 생성·수정·삭제에 인증을 보장하고 비로그인 요청은 401 반환
P1	보안 통합 테스트 추가	관리자 및 후기 쓰기 경로의 익명 요청을 회귀 테스트
P2	POST 토글 API 정리	PUT/DELETE 또는 명시적 PATCH로 멍등성 개선

2. 주요 부적합 및 감점 위험

심각

관리자 동기화 API가 인증 없이 공개됨

영향

외부 사용자가 공공데이터 전체·분류별 동기화를 반복 호출할 수 있어 외부 API 사용량, DB 쓰기 및 서버 자원을 소모시킬 수 있다. 평가표의 보안 취약점과 인증·인가 항목에서 큰 감점 가능성이 있다.

근거

SecurityConfig.java 61-68행에서 `/api/v1/admin/openapi/**` 및 `/api/v1/admin/sync/**`가 `allowUris`에 포함되고 82행에서 `permitAll` 처리된다. `PublicDataSyncController.java` 12-42행은 실제 쓰기 작업을 시작한다.

권장 조치

해당 경로를 공개 목록에서 제거하고 인증을 요구한다. 운영 관리 기능이라면 ADMIN 권한, 내부 네트워크 또는 별도 관리 토큰까지 적용한다.

심각

정보 후기 쓰기 API가 광범위한 `permitAll`에 포함됨

영향

후기 생성·수정·삭제 요청이 Spring Security 인증을 통과한다. 익명 요청에서 `userId`가 null이 되어 401 대신 500이 발생할 가능성도 있어 보안과 에러 핸들링 양쪽에 영향을 준다.

근거

SecurityConfig.java 65행의 `/api/v1/info-items/**`가 HTTP 메서드 제한 없이 공개된다. `InfoReviewController.java` 54, 69, 86행의 `POST/PATCH/DELETE`도 이 패턴에 포함되며 별도의 `@RequireSignupCompleted`가 없다.

권장 조치

광역 패턴을 제거하고 GET 조회만 `permitAll`로 둔다. 공개가 필요한 POST는 개별 경로로 한정하고 후기 쓰기 API의 익명 요청이 401을 반환하는 통합 테스트를 추가한다.

중간

POST 기반 토글 API의 비역등성

영향

동일 요청을 재시도하면 등록과 취소가 반전돼 네트워크 재시도에 취약하다. RESTful 메서드 적절성 항목에서 감점될 수 있다.

근거

정보 스크랩·도움돼요, 댓글 채택, 뉴스 스크랩 등이 POST 한 번으로 상태를 토글한다. 게시글·댓글 좋아요는 `PUT/DELETE`로 분리되어 있어 프로젝트 내부에서도 설계가 불일치한다.

권장 조치

등록은 `PUT`, 취소는 `DELETE`로 분리한다. 상태 값을 명시적으로 전달할 필요가 있다면 `PATCH`를 사용한다.

204 응답과 공통 JSON 포맷의 혼용

영향

HTTP 204는 본문이 없어야 하므로 ApiResponse를 반환해도 본문이 제거된다. 성공 응답이 항상 같은 JSON 구조라는 설명과 충돌할 수 있다.

근거

UserController.java 123-131, 154-161, 184-191행은 @ResponseStatus(NO_CONTENT)와 ApiResponse 반환을 함께 사용한다.

권장 조치

204 + 빈 본문 또는 200 + ApiResponse 중 프로젝트 규칙을 선택해 일관되게 적용한다.

3. 충족된 구현 요소

구분	확인 결과
공통 응답 포맷	ApiResponse가 isSuccess, code, message, result 구조를 성공과 실패에 공통 적용한다.
전역 예외 처리	검증 실패, 잘못된 JSON, 타입 불일치, 누락 파라미터, 파일 크기 초과 및 미처리 예외를 상태 코드와 함께 처리한다.
인증 실패 응답	401과 403을 공통 ApiResponse JSON으로 반환해 인증·인가 실패 형식이 일관적이다.
기본 보안 구성	JWT 기반 stateless 세션, Spring Security 필터, BCrypt, 제한된 CORS origin 구성이 존재한다.
비밀값 관리	DB, JWT, OAuth, S3 및 OpenAI 키는 환경변수를 참조하며 실제 .env 파일은 Git 추적 대상에서 발견되지 않았다.
DB 운영 안전성	운영 프로파일에서 ddl-auto=validate와 Flyway가 활성화되고 다수의 FK-unique constraint-LAZY 관계가 정의되어 있다.
배포 자동화	Docker 멀티 스테이지 빌드, non-root 사용자, EC2/RDS/Nginx, HTTPS 안내, health check 및 GitHub Actions 배포 흐름이 있다.
협업 체계	간소화 Git Flow, 이슈·PR 템플릿, 커밋·리뷰 규칙, CI가 문서화되어 있고 최근 커밋에 PR 병합 이력이 이어진다.

검증 규모

- 컨트롤러의 HTTP 매핑 약 87개
- src/test/java 아래 테스트 소스 92개
- 현재 브랜치 develop, 점검 전후 작업 트리 변경 없음

4. 저장소만으로 확정할 수 없는 항목

다음 항목은 코드가 아니라 실제 제출자료 또는 외부 시스템 상태를 확인해야 최종 점수를 판단할 수 있다.

항목	현재 확인 결과	제출 전 확인
API 정상 동작	전체 테스트 실행이 장시간 종료되지 않아 최종 통과 여부 미확정	깨끗한 환경에서 ./gradlew test --no-daemon 완료 및 실패 0건 확인
시연 영상 일치	영상 자료가 저장소에 없어 확인 불가	Swagger/API 명세, 시연 영상, 배포 서버의 경로·요청·응답 일치 확인
백엔드 배포 URL	bodeum.site는 HTTPS 프론트엔드로 연결되며 /actuator/health는 404	평가자가 접근 가능한 별도 백엔드 URL과 테스트 계정 제출
DB 설계 문서	엔티티와 마이그레이션은 확인했으나 팀 노선의 전체 ERD·설계 이유는 미확인	전체 ERD, 관계·정규화·비정규화 선택 이유를 팀 노선에 포함
리뷰 빈도	PR 병합과 규칙은 확인했으나 각 PR의 실제 리뷰 여부는 미확인	PR별 승인·리뷰 현황과 미리뷰 PR 비율 확인

테스트 실행 메모

최초 실행은 남아 있던 Gradle 프로세스가 build/classes를 점유해 실패했다. 해당 프로세스를 종료한 뒤 재실행했지만 제한 시간 내 완료되지 않아 실행 프로세스를 정리했다. 이 결과는 테스트 실패를 의미하지 않지만, 전체 테스트 통과를 증명하지도 않는다.

5. 제출 전 권장 체크리스트

- [필수] /api/v1/admin/openapi/** 및 /api/v1/admin/sync/**에서 permitAll 제거
- [필수] /api/v1/info-items/** 광역 공개 제거, 조회 GET만 명시적으로 허용
- [필수] 후기 POST/PATCH/DELETE 익명 요청이 401인지 통합 테스트 추가
- [필수] 전체 Gradle 테스트 완료 및 CI 성공 확인
- [필수] 배포 백엔드 URL, 테스트 계정, 인증 토큰 획득 절차 제출
- [필수] 최종 API 시연 영상과 Swagger/API 명세 일치 확인
- [문서] 전체 ERD와 제3정규형 관점의 설계 이유를 팀 노선에 포함
- [문서] 인프라 아키텍처와 EC2/RDS/Nginx/HTTPS 구성 이유를 포함
- [개선] POST 토크 API를 PUT/DELETE 또는 PATCH로 정리
- [개선] 204 응답 정책과 공통 ApiResponse 정책을 명문화
- [협업] 전체 PR 중 실제 리뷰·승인이 없는 PR 비율 확인

최종 판단

현재 구현은 공통 응답, 예외 처리, DB 마이그레이션, 배포 자동화 및 협업 문서 측면에서 완성도가 높다. 다만 관리자 API와 후기 쓰기 API의 보안 매치는 실제 배포 환경에서 심각한 취약점이 될 수 있으므로 제출 전에 반드시 수정해야 한다. 이 두 항목을 고치고 전체 테스트·배포 URL·노선 문서를 검증하면 평가 기준 대응력이 크게 향상된다.

참고 경로

SecurityConfig.java · PublicDataSyncController.java · InfoReviewController.java · InfoToggleController.java · CommentController.java · UserController.java · ApiResponse.java · GeneralExceptionAdvice.java · application-prod.yml · docker-compose.prod.yml · .github/workflows